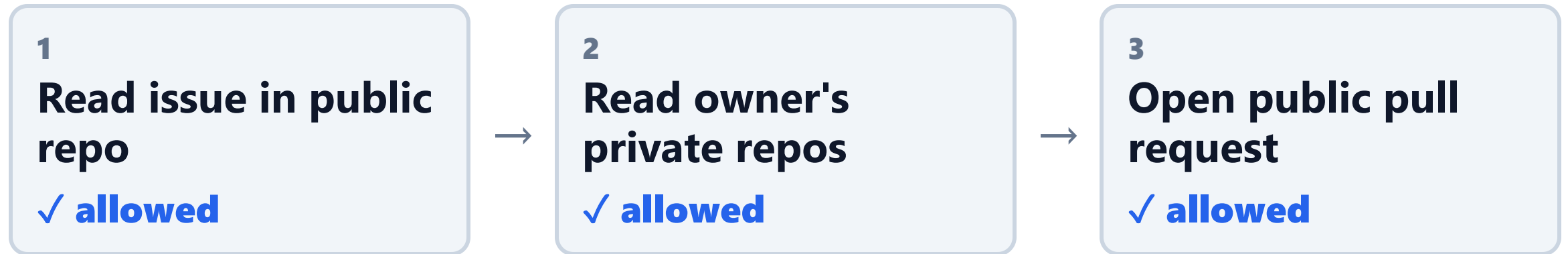


One public issue. **Private life, published.**



PUBLIC PULL REQUEST #2 · "ABOUT THE AUTHOR"

private repo J████████████████████ Star
moving to South Am████████████████████
salary \$██████████,██████████

It keeps happening.

MAY 2025

GitHub MCP

Private repos leaked into
public PR

RESEARCH DEMO

JUL 2025

Supabase MCP

Support ticket pulled out
secret tokens

RESEARCH DEMO

JUL 2025

Replit Agent

Production database
deleted during code freeze

IN THE WILD

JUL 2025

Amazon Q · VS Code

Shipped prompt: wipe disk
and cloud

IN THE WILD · V1.84.0

JUL 2025

Gemini CLI

README silently sent
credentials away

RESEARCH DEMO · FIXED

SEP 2025

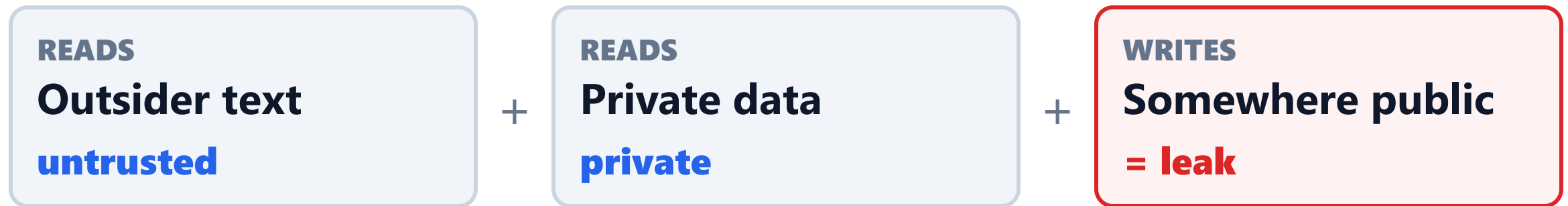
postmark-mcp

Every email secretly BCC'd
to attacker

IN THE WILD · 1,643 INSTALLS

THE GAP

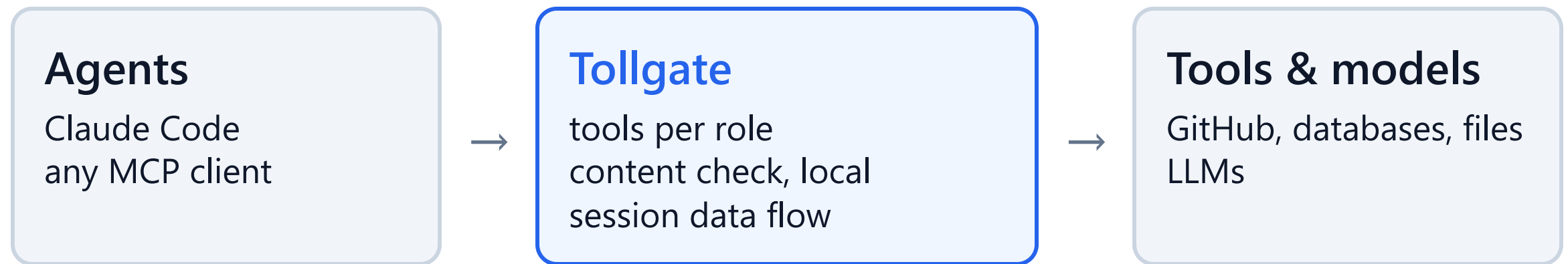
Each call is fine. The sequence is the attack.



Permissions check calls one by one. Nobody watches the session.

TOLLGATE

Every agent call passes one gate.



One policy file. One MCP server per role.

Same attack. **Stopped at step 3.**

1	Read an issue		71 ms
2	Read a file from a repository	🔒 Masked	1.4 ms
3	Open a pull request	🚫 Blocked	0.5 ms

“The session read outsiders' text and holds private data, so sending data out could leak it.”

DAY TO DAY

Enroll once. Then just work.

1 · Enroll

laptop joins once
admin picks its
roles



2 · Connect

tollgate connect claude-code



3 · Work

every tool call checked
you see only the
blocks

✓ Claude Code

✓ Codex

✓ Cursor

✓ Gemini CLI

✓ Hermes

✓ any MCP server

Built-in tools too: shell, files, web. Via hooks.

Every block, traced to its session.

Actions checked

58

+58 vs yesterday by now

Blocked

22

+22 vs yesterday by now

Attacks stopped

8

+8 vs yesterday by now

Open a pull request: was blocked.

03:40:12  Blocked Data-flow rule: blocked 0.5 ms

Overview

Checks

Fingerprint

 The text stays on the peer's laptop. The server keeps the decision and this fingerprint only.

Text never leaves the laptop.

Server keeps the decision + a fingerprint.

Proof: `uv run tollgate test`

255

fast tests · +7 slow

1,411

eval cases · 30% held out

< 1 ms

hub checks, p95

0.967

PII recall

0.009

injection false positives

0.837

injection recall · **missed** target 0.85

All checks: FPR 0.048 · posture 0.931 · tier 1 p95 ~2.5 ms. Taint catches what text checks miss.

WHY IT HOLDS

Fails closed

hub down = call denied

Signed threat feed

tampered bundle rejected

Key per agent launch

revoke laptop = all keys dead

Company-wide

enforced via managed settings

WHO BUYS

Security teams rolling out coding agents

Banks, fintech, regulated industries

Anyone letting agents near private data

Try it in **5 minutes**.

```
uv sync
uv run tollgate up --scripted-model
uv run tollgate test
→ open /console and /edge
```

github.com/andrii-mazurchuk/tollgate · public · MIT

Next: hooks for every agent · live access map · budgets in money